DETECTION THREAT LANDSCAPE

ROMULUS / CLICKFIX POWERSHELL STAGING

A behavior-led hunt for PowerShell URL staging with source-observed evasion switches, designed for Microsoft Defender XDR.

HUNTING | CONFIDENCE MEDIUM | VALUE 8/10

PRIMARY PLATFORM
Microsoft Defender XDR

CLASSIFICATION
Hunting query

PUBLISHED
18 October 2026

Untested implementation sketch. A match does not prove ClickFix delivery, payload retrieval, execution, C2, compromise, or attribution.

02 Executive Assessment

Decision-grade summary and implementation boundary.

EXECUTIVE SUMMARY

Defensible as a hunt, not yet an alert

Vedere Labs recovered ROMULUS stagers using obfuscated PowerShell, self-deletion, URL retrieval and, on one route, silent MSI installation. The portable observable is PowerShell with an evasion-related switch and an HTTP(S) URL.

DECISION

Medium confidence hunting logic

The signal is visible in Defender XDR, but administrators and deployment tools can legitimately combine these switches with URLs. Local prevalence and parent-process baselining are mandatory before alerting.

8/10

OPERATIONAL VALUE

HUNT

UNTESTED STATUS

01

BEHAVIORAL SIGNAL

SOURCE FACTS

Observed behavior

Recovered stagers used PowerShell to retrieve payloads. Source guidance calls out -NoProfile, -ep bypass or -w hidden together with a URL.

INTERPRETATION

Behavioral value

The conjunction is more discriminating than either signal alone and remains useful when campaign domains rotate.

ASSUMPTION

Telemetry dependency

DeviceProcessEvents retains complete command lines and PowerShell execution is not normalized or redacted.

03 Threat Mechanics

Evidence-bounded decomposition of the observed delivery routes.

01
USER ACTION
ClickFix lure

02
STAGER
Obfuscated PowerShell

03
TRANSFER
MSI or 7z

04
PAYLOAD
Loader execution

Stage	Confirmed behavior	Observable evidence	Detection value
Staging	Integer-array obfuscation and [scriptblock]::Create	PowerShell command line; optional 4104	Durable structure; collection-dependent
Route A	Temp download; Unblock-File; msiexec /i /qn /norestart	Process and file telemetry	Strong chain; correlation needed
Route B	7zr.exe; two passworded extractions; inflated PE	Process lineage and file size	High investigative value
C2	Form-urlencoded POST with one Base64 blob	Decrypted HTTP body	Unavailable without inspection

Boundary: the published hunt implements only the first process signal. It does not claim payload retrieval, MSI execution, archive extraction, successful C2, or compromise.

04 Telemetry and Evidence Model

Required fields, enrichment and known blind spots.

REQUIRED TELEMETRY

Defender for Endpoint process creation

DeviceProcessEvents with complete ProcessCommandLine, device identity and initiating-process context.

OPTIONAL ENRICHMENT

Script, file and network evidence

PowerShell 4104, DeviceFileEvents, DeviceNetworkEvents, signer data and approved automation inventory improve verdict quality.

Field	Reliability	Purpose
Timestamp	Documented	Event ordering
DeviceName, DeviceId	Documented	Host correlation
FileName	Documented	Interpreter filter
ProcessCommandLine	Documented; population environment-dependent	Switch and URL evidence
InitiatingProcessFileName	Documented	Parent-process tuning
ReportId	Documented	Uniqueness with device and time

UNAVAILABLE

Not inferred

Clipboard content, web-page provenance, HTTP body, archive contents and script semantics are not inferred from process telemetry.

FAILURE CONDITION

Coverage gap

The hunt fails if command lines are absent, truncated, encoded without visible URLs, or executed through a different interpreter.

05 Defender XDR Hunting Query

Behavioral signal with no arbitrary threshold or aggregation.

```
// ROMULUS ClickFix PowerShell URL staging
// Classification: Hunting query - Untested implementation sketch
// Confidence: Medium
// Platform: Microsoft Defender XDR Advanced Hunting
// Telemetry: DeviceProcessEvents
// A result identifies PowerShell with source-supported evasion switches plus a URL.
// It does not prove ClickFix delivery, payload retrieval, execution, C2, or compromise.
DeviceProcessEvents
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine has_any (
"-NoProfile", "-nop",
"-ExecutionPolicy Bypass", "-ep bypass",
"-WindowStyle Hidden", "-w hidden"
)
| where ProcessCommandLine contains "http://"
or ProcessCommandLine contains "https://"
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
FolderPath, SHA1, InitiatingProcessFileName,
InitiatingProcessCommandLine, InitiatingProcessFolderPath,
InitiatingProcessAccountName, ReportId, DeviceId
| order by Timestamp desc
```

CONDITION EVIDENCE

Source-supported conjunction

Interpreter, evasion switches and URL are explicitly recommended by the source as ROMULUS detection opportunities.

DESIGN CHOICES

Simple and investigable

No join, sequence, count, rarity, threshold or IOC. Parent context remains available for analyst-led tuning.

06 Secondary Platform Decisions

Atomic validation only; no mechanical query translation.

SPLUNK

No reliable implementation can currently be written

Missing: confirmed index, sourcetype, parser and extracted fields for Windows process creation and complete command line. Validation: collect a benign PowerShell event with a URL and one switch; confirm raw event, parent, host, user and command-line extraction. Only then write an atomic direct search using customer-confirmed fields.

CHRONICLE / YARA-L 2.0

No reliable implementation can currently be written

Missing: verified parser and raw-to-UDM mapping for process command line and parent process. Validation: ingest one controlled event, inspect UDM Search, and verify metadata.event_type, process command line, principal host/user and parent mapping before authoring a single-event rule.

Reason: inventing SPL fields or UDM mappings would create syntactically plausible but operationally unreliable content. Secondary support remains a concrete schema-validation plan.

07 Triage, Tuning and Test Plan

Criteria for promotion, rejection and failure.

BENIGN OVERLAP

Expected legitimate sources

Software deployment and bootstrap scripts; administrator download-and-install workflows; security tooling; incident-response scripts; developer setup automation.

TUNING

Ownership-backed dimensions

Approved script hash or package owner; known parent process; managed deployment path; expected account, host group and destination. Review full chain before allowlisting.

VALIDATION STEPS

Four controlled experiments

1. Run a benign PowerShell command with one listed switch and an HTTPS URL.
2. Confirm complete command line and initiating-process fields.
3. Measure 14 days without alerting and label known automation.
4. Replay a safe simulation and verify investigative output.

Criterion	Decision
Success	Controlled event returns intact URL, switch, device, account and parent context.
Promotion gate	Benign overlap is low or constrained by stable ownership-backed exclusions.
Rejection	Results are dominated by legitimate automation that cannot be safely distinguished.
Failure	Command lines are missing/truncated or coverage is materially incomplete.

08 ATT&CK, Limitations and References

Direct mappings only; references are defanged.

T1059.001	T1105	HUNTING	HIGH
PowerShell stagers	Ingress transfer	Medium confidence	Feasibility

LIMITATIONS

Behavioral but incomplete

No clipboard, script-body, downloaded-content or decrypted-HTTP inspection. Encoded, indirect or alternate-interpreter execution may be missed. Attribution is not established.

UNCONFIRMED

Source boundaries

ROMULUS ownership, shared-service model, common ownership of payload families and unanalyzed MSI routes remain unconfirmed.

PRIMARY AND OFFICIAL REFERENCES

Forescout Research - Vedere Labs — ROMULUS: Analysis of a New Multi-Payload ClickFix Delivery Platform. 15 Oct 2026.

`hxxps://www[.]forescout[.]com/blog/romulus-analysis-of-a-new-multi-payload-clickfix-delivery-platform/`

Microsoft — DeviceProcessEvents table in the advanced hunting schema. Accessed 18 Oct 2026.

`hxxps://learn[.]microsoft[.]com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table`

MITRE ATT&CK; — T1059.001 PowerShell; T1105 Ingress Tool Transfer. Accessed 18 Oct 2026.

`hxxps://attack[.]mitre[.]org/techniques/T1059/001/ · hxxps://attack[.]mitre[.]org/techniques/T1105/`

Final status: Hunting query - Untested implementation sketch. Validate in the target environment before any alerting or response automation.